



Executive summary

AI AGENT + MCP + SKILL SECURITY REVIEW

Scope: Selected source directory; paths below are relative | Invarune 0.15.0

No configured risk patterns detected

The selected static scope completed without a detector match. This is not a security pass. Review the unassessed boundaries and validate the controls below.

0

OPEN FINDINGS

0

COVERAGE GAPS

2

FILES EXAMINED

Observed counts only. This is not an accuracy score or a security grade.

Deterministic layer: Selected static scope completed.

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered.

No open finding groups. Review accepted exceptions, coverage limits and active controls before drawing a deployment conclusion.

[Record a review decision and rescan](#)

Justified and disabled are human decisions, not passes. The full review forms and all evidence remain in this report.

Scan ID: da4d62e183b5547b3271a025705316305a4112899c8b700c67c7ba3805b003dd



Contents

Executive summary	1
Contents	2
Priorities and first actions	3
Metrics and calculation	4
Observed findings and mitigating layers	5
Optional advisory review and evidence	6
Coverage gaps and required validation	8
Control checklist and evidence requirements	9
Scan configuration and scope	10
Deterministic checks and optional review	13
Coverage, misses and validation by area	14
Appendix / Deterministic rule inventory	21
Interactive review workspace	22



Priorities and first actions

Optional model review: finding stage completed; control stage completed. 0 model answers from 0 selected findings; 0 open findings outside the cap. 0 acceptance checks remain unanswered.

Severity counts describe observed open patterns. They do not establish exploitability or an estimated probability of compromise.

Critical		0
High		0
Medium		0
Low		0
Info		0

Severity counts use the existing scanner rules; no model or reviewer score is added.

Fix guidance: 0/0 findings have deterministic fix plans and agent/MCP context. Model fix plans: 0/0 finding assessments; 2/2 answered checks. Proposals require verification.

Review every detailed finding and gap below. Additional concerns can exist outside this bounded scan's supported syntax, files, budgets and execution context.



Metrics and calculation

No defensible universal security percentage can be calculated from static patterns or model opinions. Zero findings and 100% answered checks do not mean secure or compliant.

Measure	Result	Interpretation
Open deterministic findings	0 (0 critical/high)	Observed pattern counts. No severity weights or compromise probabilities are assigned.
Partial deterministic mapping reach	100.00% (1/1)	Active selected controls with an active selected mapped rule. Available partial coverage, not a pass rate.
Optional AI answer coverage	100.00% (2/2)	Active selected checks with a model answer, including concerns and unknowns. Review completion, not safety.

Selected scope: 1 rules (1 active); 1 controls (1 active); 2 active acceptance checks. 0 recorded coverage gaps.

Exact formulas

$100 \times \text{active selected controls with at least one active selected mapped rule} / \text{active selected controls}$. This describes partial rule availability, not completed tests, passes, or control effectiveness.

$100 \times \text{unique active selected acceptance checks with a received, valid model answer} / \text{active selected acceptance checks}$. An answer can be a concern or an explicit unknown. Disabled AI has zero answered checks; an empty denominator is not applicable (null), never 100%.

Advisory AI outcomes

Check outcome	Count
supported_by_code	0
potential_gap	1
needs_runtime_validation	0
needs_human_review	0
insufficient_evidence	1
not_applicable_proposed	0
not_reviewed	0

Supported by code and proposed non-applicability are advisory interpretations. Runtime/human validation and missing evidence remain unresolved. AI cannot erase findings, lower their severity, change the severity gate, or turn checks into passes.

Justified and disabled rules/checks are excluded from active metric denominators without pass credit. Findings with user decisions or baseline suppressions remain visible outside open-finding counts. Selection narrows the requested scope; it does not establish the excluded system is safe.

The existing CLI gate uses open deterministic findings at or above the configured severity. Scan/review/export errors can make requested work incomplete. Coverage percentages and model opinions never dismiss the gate.



Observed findings and mitigating layers

No selected static pattern was emitted. Review coverage gaps and control evidence before drawing a conclusion.



Optional advisory review and evidence

Model interpretations are advisory. They do not dismiss static findings, prove control effectiveness or change deterministic evidence. A verified quotation proves its presence in the supplied excerpt, not the correctness of the interpretation.

Omissions, evidence collection limits, errors and budgets are recorded in the optional-review summary above. Proposed verification steps have not been executed by this scanner.

Bounded evidence investigation

Follow-up rounds: 1. Requests served / denied: 1 / 0. Captured files offered: 2. All requests share the configured call and evidence budgets; target tools and code are never executed.

EXEC-05:1 / file-01133ae2e5e076d2cc2525ac:13-36 / counterevidence / served

Reason: The caller-selected URL reaches requests.post through dispatch with lane 1. Inspect `_admit` and its surrounding definitions to determine whether that lane enforces destination and scheme restrictions before the network operation.

Counterevidence: Seek effective lane-specific allowlists, URL parsing, address restrictions, and DNS enforcement. Determine whether the constant destination used by lane 0 constrains lane 1 as well; redirects are already explicitly disabled at the visible request.

EXEC-05 / Advisory check review: reviewed

Check 1 / potential_gap

The visible caller-selected URL enters dispatch with lane 1. The admission predicate accepts that lane independently of the destination, allowing the URL to reach requests.post without a visible destination or scheme restriction in this flow. Redirects are explicitly disabled, which limits redirect-based exposure. The constant destination used by the sibling lane does not constrain lane 1. Connection-time address restrictions and DNS enforcement are not established by the supplied evidence. This is an unverified concern in a declared inert fixture, not evidence of deployed exploitability.

Risk hypothesis: A caller could select an internal or metadata destination and reach requests.post because lane 1 makes `_admit` true regardless of the URL.

Trust boundary: The visible boundary is caller-controlled `user_url` entering `tool_forward`, crossing the admission predicate, and becoming the destination of a server-side HTTP POST. Actual agent or MCP registration is not supplied.

Counterevidence considered: The rejection branch is present, but its predicate does not restrict lane 1. The sibling caller uses a constant destination on lane 0, and redirects are disabled. The excerpts describe an inert fixture. These alternatives limit the claim but do not establish destination restrictions for lane 1.

Conclusion limits: Only the local flow is established. No code was executed, and deployed reachability, library behavior, DNS handling, network isolation, and external egress policy remain unresolved.

Model supplied this advisory interpretation.

Evidence src-ea8f5ad7a1e9b55c0a223d85 / agent.py:7-7

Quoted excerpt: `return dispatch(1, user_url, user_content)`

Evidence src-c76b9846c312b1d8e2392d1c / delivery.py:17-18

Quoted excerpt: `def _admit(a, b):
return a == 1 or b == "https://approved.invalid"`

Evidence src-6a02164f7498f198ded37c26 / delivery.py:37-41

Quoted excerpt: `def dispatch(lane, addr, record):
if not _admit(lane, addr):
raise ValueError("Unsupported destination")
return requests.post(addr, json={"record": record}, timeout=5,
allow_redirects=False)`

Verification still required: Have the owner establish whether this fixture represents a reachable agent or MCP tool and identify caller authorization and external egress restrictions.

Verification still required: Review the deployed transport and destination policy for allowed schemes, resolved IPv4 and IPv6 addresses, and enforcement against the actual connection destination.

Verification still required: In an authorized isolated environment, verify that disallowed destinations cannot receive a connection and that redirect responses are never followed.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: If exposed as an agent or MCP tool, caller-controlled `user_url` crosses into server-side outbound HTTP, potentially using network access unavailable to the caller.

When this applies: Apply changes to any operational implementation represented by this fixture. Deployment reachability and existing transport or egress controls require owner confirmation.



1. Replace the unconditional lane-1 admission with a destination policy applied to every caller-controlled URL; explicitly allow required schemes and approved destinations.
2. Enforce resolved-address restrictions at connection time through a controlled transport or egress proxy, covering loopback, private, link-local, metadata, and IPv6 destinations without a validation-to-connection DNS race.
3. Retain `allow_redirects=False`. If redirects become necessary, validate every target and its connection destination before following it.

Verify: Review that every relevant lane invokes the same destination policy and cannot bypass it through lane selection.

Verify: Use isolated transport observations to verify blocked addresses receive no connections, including after DNS changes.

Verify: Retain regression coverage showing redirect responses are not followed.

Check 2 / insufficient_evidence

The supplied excerpts contain no test cases or results covering loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, or redirects to private destinations. Disabling redirects is relevant implementation evidence but does not establish that these cases were tested. The declared fixture context further limits conclusions about operational coverage; omitted tests may exist.

Risk hypothesis: Incomplete destination testing could leave lane-dependent admission bypasses or address-interpretation differences undetected.

Trust boundary: Required coverage spans caller-provided URLs, admission decisions, DNS resolution, actual outbound connections, and redirect handling.

Counterevidence considered: The visible request disables redirects, reducing one relevant exposure. The fixture declaration was considered as a possible nonoperational context. Neither establishes test coverage; tests outside the submitted excerpts remain possible.

Conclusion limits: No test suite, case matrix, or runtime results were supplied. Test absence and operational applicability cannot be inferred, and runtime validation remains outstanding.

Model supplied this advisory interpretation.

Evidence `src-1c85609fb313cbfd95eb25cd / delivery.py:1-1`

Quoted excerpt: `"""Inert review fixture: network calls below must never be executed."""`

Evidence `src-6a02164f7498f198ded37c26 / delivery.py:40-41`

Quoted excerpt: `return requests.post(addr, json={"record": record}, timeout=5, allow_redirects=False)`

Verification still required: Request the relevant test inventory and results covering every required address class, alternate encodings, and redirects to private destinations.

Verification still required: Have the owner validate the operational implementation in an authorized isolated harness with controlled DNS and connection observations, including both visible caller lanes.

Model-proposed fix guidance (unverified)

Agent/MCP relevance: Destination tests should exercise the caller-controlled tool boundary through to the outbound transport, since predicate-only tests cannot establish which destination actually receives a connection.

When this applies: First identify the operational implementation and existing tests. Do not execute the submitted inert fixture or contact real metadata or internal services.

1. Obtain existing test artifacts before concluding that coverage is missing.
2. Where coverage is missing, add isolated cases for loopback, private and link-local IPv4 and IPv6, metadata destinations, alternate address encodings, and redirects to prohibited destinations.
3. Include controlled DNS changes and assert the observed connection destination; cover lane 1 and the fixed-destination sibling to detect lane-dependent bypasses.

Verify: Have an owner review the case matrix against every address category in this acceptance check.

Verify: Retain isolated test results demonstrating rejection before prohibited connections and no follow-up connection after a redirect response.



Coverage gaps and required validation

No operational gap was recorded within the selected scope. Unsupported runtime properties still require their own checks.



Control checklist and evidence requirements

EXEC-05 / Prevent SSRF and unsafe network destinations

Scanner status: no_pattern_detected | validation: hybrid

1. Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

[Record review for EXEC-05:1](#)

2. Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

[Record review for EXEC-05:2](#)

https://modelcontextprotocol.io/docs/2026-07-28/tutorials/security/security_best_practices



Scan configuration and scope

Source scope and limits

Setting	Configured value
Default excluded directories	.cache, .git, .hg, .mypy_cache, .next, .pytest_cache, .svn, .tox, .venv, __pycache__, build, coverage, dist, node_modules, vendor, venv
Exclude	None
Explicit exclusion identity scope	Existing selected files and directories, including case aliases and file hardlinks; inputs must remain stable during the scan. Device/inode identities are not persisted in reports.
Explicit exclusion matching	resolved_paths_and_snapshot_filesystem_identities
Generated outputs and judge config excluded	Yes
Max entries	100000
Max file bytes	1000000
Max files	20000
Max total bytes	50000000
Requested scan ids	EXEC-05
Selected control ids	EXEC-05
Selected rule ids	AI014



Invocation and optional-review budgets

Setting	Configured value
Optional review / Analyst limits / Batch size	1
Optional review / Analyst limits / Investigation rounds	2
Optional review / Analyst limits / Max bytes	2000000
Optional review / Analyst limits / Max calls	3
Optional review / Analyst limits / Max chars	120000
Optional review / Analyst limits / Max files	200
Optional review / Analyst limits / Max seconds	900.0
Optional review / Cli login	never
Optional review / Cli timeout seconds	300.0
Optional review / Effective transport / Max request bytes	524288
Optional review / Effective transport / Max response bytes	1048576
Optional review / Effective transport / Model	gpt-6-astra
Optional review / Effective transport / Provider	codex_cli
Optional review / Effective transport / Timeout seconds	300.0
Optional review / Effective transport / Token optimizer	headroom
Optional review / Enabled	Yes
Optional review / Findings limit	100
Optional review / Include finding source	No
Optional review / Mode	full
Optional review / Provider	codex_cli
Optional review / Transport replay	Endpoints, credentials, headers, executable paths and identity stores are not embedded for automatic replay.
Reporting / Failure threshold	high
Reporting / Formats	html, markdown, json, sarif, pdf
Review inputs / Baseline	No



Setting	Configured value
Review inputs / Review config	No
Review inputs / Review report	No
Schema version	1.0

Image limits

Not present for this scan.

Source and image evidence are static. Image metadata, retained layers and packaged files do not reveal every runtime override or compiled program behavior.

Scanner provenance

Identity	Recorded value
Display name	Invarune by NimeshBuild
Implementation sha256	525747fc453830a4bc93b887c21161ff44c21212af1a525bbd5a9d615086954b
Name	agent-mcp-security-scan
Python version	3.12.14
Version	0.15.0



Deterministic checks and optional review

1 selected deterministic rules (1 active)

Deterministic checks inspect bounded Python syntax and local value flow, JavaScript/TypeScript lexical structure, structured JSON, configuration settings, selected secret patterns and image metadata. Repeated stable input produces repeatable evidence; it does not guarantee zero false positives or negatives.

Optional security analyst

If enabled, a model reviews selected findings and acceptance checks using bounded supplied evidence. Strict IDs, citations, response validation and tool restrictions constrain the protocol. Partial budgets, omitted answers and unavailable source/runtime evidence remain visible. Advice does not independently prove safety or erase static findings.

Review layer	Actual outcome / coverage
Finding review	completed; 0 selected; 0 outside cap
Control review	completed; 1/1 active controls answered
Unanswered acceptance checks	0/2 requested checks
Control requests	2/3 configured calls
Finding-stage error	None recorded
Control-stage errors	None

What can be missed

Cross-module/interprocedural flow, reflection, dynamic loaders, complex language syntax, templates before rendering, unsupported languages, compiled image behavior, runtime authentication/authorization, tenant isolation, egress policy, dependency CVEs and adaptive prompt injection require additional validation. A source declaration or proposed mitigation is not deployment evidence.

Human/runtime review workflow

1 / SELECT

Source or built image

2 / INSPECT

Deterministic evidence

3 / OPTIONAL

Bounded analyst review

4 / VALIDATE

Runtime / human tests

5 / RECORD

Decision + reason + owner

6 / RECHECK

Fresh scan + bound import

1. Review evidence and the immediate concern. 2. Record a decision, reason, reviewer, date and evidence reference. 3. Validate runtime or human-dependent controls in the applicable environment. 4. Save and import the edited PDF or equivalent JSON. 5. Resolve rejected/stale edits, then rescan. Gaps remain operationally incomplete; blank decisions retain existing scanner semantics.



Coverage, misses and validation by area

Controls with rule mapping		1
Controls without rule mapping		0

Catalog mapping counts are not passed controls or percent secure.

Mapping counts describe available checks, not percent secure, detection accuracy or validated control effectiveness.

Execution and data flow

Deterministic: Python AST checks propagate selected registered-tool inputs and same-file arguments/returns, retain aliases and exact literal constraints, and check selected execution/file/network sinks. JavaScript tokens support narrow registerTool callbacks and direct-return named/arrow wrappers. Explicit world-writable chmod modes are checked.

Optional analyst: A model can form a trust-boundary hypothesis, request bounded captured source ranges to inspect callers or guards, seek counterevidence and explain what the supplied code still cannot establish.

Can miss or misclassify: Cross-file flows, unknown decorators/methods, complex JavaScript wrappers, dynamic imports, reflection, generated code and runtime values can hide a risk. Recognized resource/binding failures remain gaps. A dangerous API can be intentional and correctly constrained.

Validate elsewhere: Exercise actual entry points with authorized negative tests; verify input provenance, execution privileges and sandbox boundaries.

MCP identity, authorization and tools

Deterministic: Selected configuration/code signals flag insecure transport, explicit authentication bypass, token passthrough, broad tool grants and unpinned server launch packages.

Optional analyst: A model can review supplied authorization logic, tool descriptions and trust-boundary evidence for missing assumptions or inconsistent checks.

Can miss or misclassify: Configuration may differ from deployment. External gateways, identity providers, token audience checks and tenant boundaries may be absent from retrieved evidence.

Validate elsewhere: Test expired/wrong-audience tokens, cross-tenant access, per-tool authorization, consent binding and the deployed MCP transport.

Prompt injection, retrieval and memory

Deterministic: Selected patterns identify external content placed in privileged model messages and explicit approval/sandbox bypass. This is not an attack simulation.

Optional analyst: A model can reason about untrusted-content handling, persistent memory, tool-output influence and missing approval boundaries in the supplied excerpts.

Can miss or misclassify: Adaptive attacks, multi-turn interactions and tool chains depend on runtime behavior. Retrieval can omit the relevant code; a model can overlook an attack or be influenced by hostile evidence.

Validate elsewhere: Run isolated adversarial agent/MCP evaluations with attack-success and legitimate-task measurements, plus human review of consequential actions.

Secrets and data handling

Deterministic: Selected literal credentials, plausible private-key material, credential-bearing URLs, logging patterns and browser credential exposure are flagged and redacted best-effort.

Optional analyst: A model can identify sensitive data flows and retention concerns when the supplied evidence explains their context.

Can miss or misclassify: Encoded, split or runtime-fetched credentials can be missed; labels/test values can resemble secrets. Neither layer establishes whether a credential is live or redaction is complete.

Validate elsewhere: Verify secret stores, credential rotation, logging/retention policy, egress destinations and actual data-access permissions.

Skills and malicious-tool indicators

Deterministic: Bounded skill/tool/schema descriptions are checked for instruction hijacking, sensitive-data transfer, covert or approval-bypassing actions. Selected Spanish/French/German overrides and paired authority claims supplement English predicates. Python read-only tool annotations are compared with recognized direct write witnesses.

Optional analyst: A model can review intent, indirect social engineering, skill reference context and tool behavior visible in retrieved evidence, including cases where syntax or supported patterns are inconclusive.

Can miss or misclassify: A pattern is risk evidence, not proof of malicious authorship. Obfuscation, remote references, external packages, omitted context and runtime behavior can evade either layer.

Validate elsewhere: Inspect publisher provenance and the exact installed skill/tool; test consequential actions in an authorized isolated environment and verify effective permissions.



Built images and supply chain

Deterministic: Image archives are reconstructed without starting containers; supported packaged source, metadata, retained credentials, stored permissions and package inventories are inspected.

Optional analyst: A model can interpret supplied image/source evidence, flag missing deployment context and propose verification work.

Can miss or misclassify: Compiled logic, live deployment overrides, signature trust and dependency CVEs are not assessed. Package inventory and archive consistency do not establish safety or publisher identity.

Validate elsewhere: Use vulnerability/advisory analysis, provenance/signature verification and deployment testing alongside the static image assessment.

Operations and control effectiveness

Deterministic: The catalog retains governance, monitoring, recovery, approval and isolation checks even where no deterministic rule maps to them.

Optional analyst: Full review queues every active acceptance check and can identify evidence gaps or propose runtime/human validation; it can cite exact submitted source text.

Can miss or misclassify: A valid citation proves that a quote exists, not that the model's interpretation is correct. Policies, external services, incident procedures and production outcomes may be unavailable.

Validate elsewhere: Record owner-reviewed evidence, operational exercises and runtime results. A written justification remains an accepted exception, never an automatically validated pass.

Optional request payload optimization

Request	Requested / actual engine	Outcome	Evidence payload bytes
Finding request	headroom / headroom	optimized	1226 -> 1182 44 bytes saved
Control request 1	headroom / headroom	optimized	5331 -> 5164 167 bytes saved
Control request 2	headroom / headroom	optimized	6723 -> 6506 217 bytes saved

These are measured evidence-JSON bytes, excluding instructions, response schemas and provider wrappers. Token and cost savings were not measured. Evidence-preserving formatting does not validate the model's interpretation.



Optional-review audit details

Recorded field	Recorded value
Analyst / Check status counts / Insufficient evidence	1
Analyst / Check status counts / Potential gap	1
Analyst / Coverage / Attempted controls	1
Analyst / Coverage / Batch size	1
Analyst / Coverage / Call budget	3
Analyst / Coverage / Calls made	2
Analyst / Coverage / Catalog checks	2
Analyst / Coverage / Catalog controls	1
Analyst / Coverage / Disabled checks	0
Analyst / Coverage / Disabled controls	0
Analyst / Coverage / Evidence / Budget exhausted	None
Analyst / Coverage / Evidence / Bytes charged	1243
Analyst / Coverage / Evidence / Bytes read	1243
Analyst / Coverage / Evidence / Candidate rankings dropped	0
Analyst / Coverage / Evidence / Candidate snippets	3
Analyst / Coverage / Evidence / Characters selected	1147
Analyst / Coverage / Evidence / Controls total	1
Analyst / Coverage / Evidence / Controls with evidence	1
Analyst / Coverage / Evidence / Controls without evidence	None
Analyst / Coverage / Evidence / Evidence files	2
Analyst / Coverage / Evidence / Failed read bytes charged	0
Analyst / Coverage / Evidence / File read attempts	2
Analyst / Coverage / Evidence / Files read	2
Analyst / Coverage / Evidence / Files verified	2



Recorded field	Recorded value
Analyst / Coverage / Evidence / Full repository review	No
Analyst / Coverage / Evidence / Limitations	Keyword-selected excerpts are partial context and do not prove implementation, absence, effectiveness, or compliance., Only unchanged manifest files are eligible; scanner exclusions and unsupported files remain outside this review., Credentials and environment files are excluded; other redaction is best-effort and source can contain sensitive data., Read budgets reserve one sentinel byte and conservatively charge failed read attempts, even if failure happened before any source bytes were read., No target code is executed, imported, installed, or contacted; repository instructions cannot change retrieval., Runtime behavior and missing evidence require additional validation; an empty control mapping is not a pass.
Analyst / Coverage / Evidence / Limits / Max bytes	2000000
Analyst / Coverage / Evidence / Limits / Max candidates per control	64
Analyst / Coverage / Evidence / Limits / Max chars	60000
Analyst / Coverage / Evidence / Limits / Max chars per excerpt	2000
Analyst / Coverage / Evidence / Limits / Max excerpts per control	4
Analyst / Coverage / Evidence / Limits / Max file bytes	1000000
Analyst / Coverage / Evidence / Limits / Max files	200
Analyst / Coverage / Evidence / Limits / Max lines per excerpt	12
Analyst / Coverage / Evidence / Limits / Max snippets	240
Analyst / Coverage / Evidence / Manifest files	2
Analyst / Coverage / Evidence / Requested characters selected	92
Analyst / Coverage / Evidence / Scope	bounded_excerpts_from_unchanged_scanner_manifest_files
Analyst / Coverage / Evidence / Selection method	deterministic_control_keywords_and_findings
Analyst / Coverage / Evidence / Skipped files	None
Analyst / Coverage / Evidence / Snippets selected	3
Analyst / Coverage / Excluded checks	0
Analyst / Coverage / Excluded controls	0
Analyst / Coverage / Justified checks	0
Analyst / Coverage / Justified controls	0



Recorded field	Recorded value
Analyst / Coverage / Omitted checks	0
Analyst / Coverage / Reviewed controls	1
Analyst / Coverage / Time budget seconds	900.0
Analyst / Coverage / Total checks	2
Analyst / Coverage / Total controls	1
Analyst / Coverage / Unreviewed control ids	None
Analyst / Coverage / Validated controls	0
Analyst / Enabled	Yes
Analyst / Errors	None
Analyst / Status	completed
Judge / Cli / Arguments	-a, never, exec, --ignore-user-config, --ignore-rules, --ephemeral, --skip-git-repo-check, --sandbox, read-only, --json, --color, never, --disable, shell_tool, --disable, unified_exec, --disable, code_mode, --disable, code_mode_host, --disable, computer_use, --disable, browser_use, --disable, browser_use_external, --disable, browser_use_full_cdp_access, --disable, in_app_browser, --disable, image_generation, --disable, view_image, --disable, artifact, --disable, apps, --disable, plugins, --disable, plugin_sharing, --disable, hooks, --disable, multi_agent, --disable, multi_agent_v2, --disable, skill_search, --disable, workspace_dependencies, --disable, shell_snapshot, --disable, memories, --disable, sleep_tool, --disable, goals, --disable, remote_plugin, --disable, tool_suggest, -c, web_search="disabled", -c, mcp_servers={}, -c, project_doc_max_bytes=0, -c, skills.include_instructions=false, -c, model_reasoning_effort="high", --output-schema, <private temporary directory>/response-schema.json, --model, gpt-6-astra, -
Judge / Cli / Auth mode	cli_managed
Judge / Cli / Cli version	0.154.0
Judge / Cli / Descendant termination	process_group
Judge / Cli / Executable	codex
Judge / Cli / Isolation	CLI capability restrictions; installed executable and administrator policy remain trusted
Judge / Cli / Provider	codex_cli
Judge / Cli / Repository working directory	No
Judge / Cli / Request bytes	3396
Judge / Cli / Request sha256	07f23c33ca00a89807c04ab5954dc222c8bbb9bf6c5c2c9986ef4d33529385c9
Judge / Cli / Requested model	gpt-6-astra
Judge / Cli / Response bytes	655



Recorded field	Recorded value
Judge / Cli / Response sha256	f779930b876f5b78e85dbaf568422318f563240f5b7a780bab1231b018af62b
Judge / Cli / Stage	findings
Judge / Cli / Startup warnings	codex_code_mode_intentionally_disabled
Judge / Cli / Structured output requested	Yes
Judge / Cli / Token budget enforced	No
Judge / Cli / Token optimization / Bytes saved	44
Judge / Cli / Token optimization / Engine	headroom
Judge / Cli / Token optimization / Evidence preserved	Yes
Judge / Cli / Token optimization / Fallback reason	Not configured
Judge / Cli / Token optimization / Headroom version	0.37.0
Judge / Cli / Token optimization / Original payload sha256	3376aade7785df1a0afe1423b2b04e48415eb95524e93f74a941e22858041be6
Judge / Cli / Token optimization / Payload bytes after	1182
Judge / Cli / Token optimization / Payload bytes before	1226
Judge / Cli / Token optimization / Requested	headroom
Judge / Cli / Token optimization / Schema version	1.0
Judge / Cli / Token optimization / Scope	Evidence JSON only; excludes instructions, response schemas and provider wrappers
Judge / Cli / Token optimization / Sent payload sha256	efd0f5b1025ed343d0da64453c6b1074f5b4c8ab412c57f5bdbd0d9bbab2eb9b
Judge / Cli / Token optimization / Status	optimized
Judge / Cli / Token optimization / Token savings measured	No
Judge / Cli / Tools policy	disabled_for_advisory_review
Judge / Cli / Transport	official_cli
Judge / Enabled	Yes
Judge / Model	gpt-6-astra
Judge / Omitted open findings	0
Judge / Provider	codex_cli



Recorded field	Recorded value
Judge / Selected findings	0
Judge / Source context requested	No
Judge / Source context sent count	0
Judge / Source context skipped	None
Judge / Status	completed



Appendix / Deterministic rule inventory

Only selected rules appear here. User-justified and disabled selections remain recorded in the decision audit and do not earn pass credit.

AI014 / Externally influenced outbound request

An outbound request uses an obvious external-input expression. This is a review signal for SSRF; this local analysis cannot prove whether upstream URL validation exists.



Interactive review workspace

Every bound item below remains tied to its original evidence. Blank means unreviewed. Any nonblank decision requires a reason; justified/disabled also require a reviewer. Coverage gaps cannot be justified or disabled. Runtime/human decisions identify outstanding validation and are not passes.

Long fields scroll in compatible PDF viewers. Save with regenerated appearances. If your editor flattens the form or cannot preserve it, use the JSON review workspace instead.

Acceptance check review

[Back to evidence](#)

EXEC-05:1 Restrict destinations and schemes at connection time; revalidate DNS resolution and each redirect.

Evidence binding: fd831b2d29a514ba09a917ddc9ad117f06287052030abc3272a928e2e58aff0d

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE

Acceptance check review

[Back to evidence](#)

EXEC-05:2 Test loopback, private/link-local IPv4 and IPv6, cloud metadata, alternate encodings, and redirect-to-private cases.

Evidence binding: a733931c250c834626baefc91c10f32a139dd325c5fd295fe6713285d66cc4b3

DECISION

Unreviewed

REVIEWER

REASON / JUSTIFICATION

REVIEWED AT (YOUR DATE)

EVIDENCE REFERENCE